



TECHNICAL SPECIFICATIONS ON NAPAS SYSTEM CONNECTIVITY <Apply for Member Institution>

PART IV: SECURITY AND COMMUNICATION

NATIONAL PAYMENT CORPORATION OF VIETNAM

Ha Noi, May, 2017



TABLE OF CONTENTS

1	AUDIENCE	7
2	SCOPE	7
3	TERMS AND ACRONYMS	7
4	MESSAGE ENCRYPTION AND SECURITY	8
4.1	KEY EXCHANGE AND MANAGEMENT	8
4.1.1	Key management principles	8
4.1.2	Hardware Security Module (HSM)	8
4.1.2.1	Operation Model	8
4.1.2.2	Hardware security levels	9
4.1.2.3	HSM configuration	10
4.1.3	Key Management	11
4.1.3.1	Types of Keys	11
4.1.3.2	Key generation, Delivery and Storage	12
4.1.4	Zone Master Key (Master Key)	13
4.2	PIN ENCRYPTION AND DECRYPTION	14
4.2.1	PIN encryption and transfer	14
4.2.2	PIN Block Format	15
4.2.3	PIN encryption algorithm	17
4.3	MAC GENERATION	19
4.3.1	Purposes of MAC	19
4.3.2	Fields for generating MAC (MACing)	19
4.3.3	MAC Generation/Verification	20
4.3.4	Handling for MAC error	20
4.4	SPECIFICATIONS FOR DLL ON CHECKSUM VALUE GENERATION AND VERIFICATION IN EXCHANGED FILE	21
4.4.1.1	Function for generating 32 byte checksum value from an original string input	21
4.4.1.2	Function for checking verifying checksum value with an original input string	21
5	PGP IN FILE EXCHANGE SECURELY	22
5.1	INTRODUCTION ON PGP (PRETTY GOOD PRIVACY)	22
5.2	OPERATION PROGRAM	23
5.3	FILE TRANSFER SECURELY AT NAPAS	24
5.3.1	Status – Requirements	24
5.3.2	Specifications	24
5.3.2.1	Session Key, Private Key, Public Key	24
5.3.2.2	Encryption Algorithm	25
5.3.2.3	File encryption	25
6	SPECIFICATIONS ON COMMUNICATION	25
6.1	CONNECTION PROTOCOL	25
6.1.1	For basic transactions on ATM/POS	25
6.1.2	For Online switching Service	26
6.1.3	For Inter-Bank Fund Transfer 24/7 (IBFT)	26
6.2	CONNECTION TELECOMMUNICATION	27
6.2.1	Specifications	27
6.2.2	Information on network	27
7	REQUIREMENTS FOR PCI DSS COMPLIANCE	28

8	EFFECTIVE DOCUMENT	29
9	DOCUMENT MANAGEMENT	29

REVISION HISTORY

Version	Release Date	Editor	Reviewer	Description for change
0.9	From 01/2016 - 11/2016	Ha Nam Ninh Nguyen Hung Cuong Bui Thi Kim Dung Pham Minh Ngoc Le Anh Tuan Dao Thanh Son Huynh Cong Linh Nguyen Thanh Quynh	Nguyen Hung Nguyen	- Built draft Technical Specification Document - Spitted the document to 05 parts include: • Part I – Transaction Processing • Part II – Message format • Part III – File format • Part IV – Security and Communication • Part V – Annex - Added international transaction processing on following part: • Part VI – Annex: International Transaction Processing
1.0	12/2016	Ha Nam Ninh Nguyen Hung Cuong Nguyen Thanh Quynh Dao Thanh Son Huynh Cong Linh	Nguyen Hung Nguyen	- Added some data elements on CHIP transaction at: • Part II – Message Format: Section 6 – Data elements,

				Section 7 – Message format • Part V – Annexa: Section 4 – Response code - Updated the Online switching, Tokenization process flow synchronized with regulations for member organizations participating in the NAPAS system at: • Part I – Transaction processing, Section 4.2, 4.3, 4.5 • Part II – Message structure, Section 6.2 - Added service and interchange fees between NAPAS and Member Banks; added two fields : DE 22, DE 25 at : • Part III – Message structure : section 4.3
1.0	05/2017	Ha Nam Ninh	Nguyen Hung Nguyen	- Added section: "Specific rules: Implement MAC for IBFT service 24/7" to help

				Members (banks and Payment Intermediates) easy and convenient in integration between NAPAS and members.
--	--	--	--	---

1 Audience

“Technical Specifications on NAPAS System Connectivity” document is intended for the Member Organizations of NAPAS include but not limited to Member Banks of NAPAS and Payment Intermediaries that directly connected to card switching services.

2 Scope

This document is established with regulations of message security and communication for Member Banks while implements switching services with NAPAS.

3 Terms and Acronyms

The following table describes the terminology and acronyms used on this document:

No.	Terms/Acronyms	Description
1	PIN	Personal Identification Number
2	PAN	Primary Account Number
3	LMK	Local Master Key
4	ZMK	Zone Master Key
5	MK	Master Key
6	ZPK	Zone PIN Key
7	MAK	Message Authentication Key
8	HSM	Hardware Security Module
9	PGP	Pretty Good Privacy

4 Message Encryption and Security

4.1 Key exchange and Management

4.1.1 Key management principles

- Keys comply with ISO 11568
- Unable to access to or identify the clear-text format of any security keys.
- The system shall prevent and detect the access to any keys; prevent unauthorized changes, replacement, deletion or insertion of any keys.
- Security keys are created under a process that one or a group of security values cannot be guessed.
- A key will be replaced by a new one if the old key is under risks of being compromised, violated or damaged.
- A compromised key in a “line” will not affect other keys in other “lines”;
- A compromised key will be unable to provide any information to find out any replacement.
- A key will only be read in a device if this device is secured and does not lead to modification or replacement without authorization.
- NAPAS and members shall have key management logs. Any access to a key shall be logged including the date and time, purposes, request in written by a duly authorized person.

4.1.2 Hardware Security Module (HSM)

4.1.2.1 Operation Model

Operation model of Hardware Security Module (HSM):

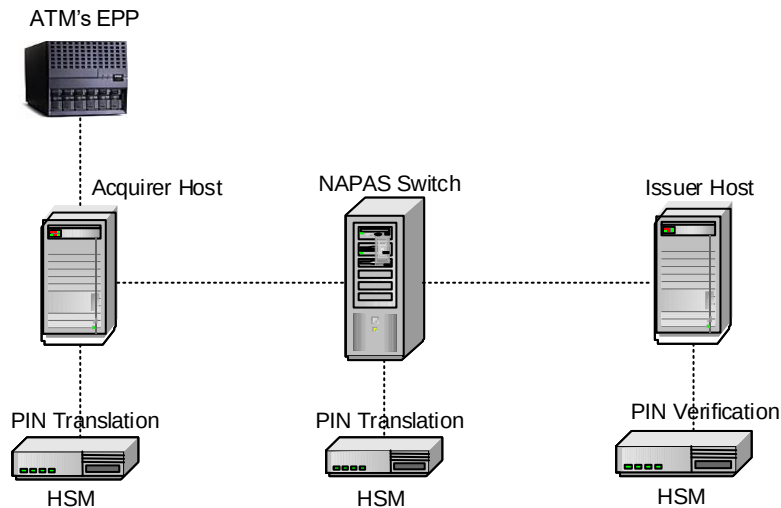


Figure 1. HSM Operation Model

In assure the data integration during transmission among parties, Acquirer Host, Issuer Host and NAPAS Switch shall use HSM to:

- Encrypt/decrypt PIN
- Generate/authenticate MAC
- Encrypt/decrypt Key

4.1.2.2 Hardware security levels

Some hardware security levels of FIPS for HSM:

a. Security Level 1:

Security Level 1 provides the lowest level of assurance and specifies basic security requirements for a cryptographic module. No specific physical security mechanisms are required in the module.

b. Security Level 2:

Security Level 2 enhances the physical security mechanisms of a Security Level 1 cryptographic module by adding the requirement for tamper-evident coatings or seals, or for pick-resistant locks on removable covers or doors of the module. Tamper-evident coatings or seals are placed on a cryptographic module so that the coating or seal must be broken to attain physical access to the critical security parameters within the module.

Tamper-evident seals or pick-resistant locks are placed on covers or doors to protect against unauthorized physical access.

Security Level 2 provides role-based authentication in which a cryptographic module authenticates the authorization of an operator to assume a specific role and perform a corresponding set of services.

c. Security Level 3:

Security Level 3 requiring advanced physical security is available in commercial products.

Security Level 3 requires identity-based authentication mechanisms, enhancing the security provided by the role-based authentication mechanisms specified for Security Level 2. A cryptographic module authenticates the identity of an operator and verifies that the identified operator is authorized to assume a specific role and perform a corresponding set of services.

Security Level 3 requires that the entry or output of the critical security parameters be performed using ports that are physically separated from other ports. Besides, the critical security parameters may either be entered into or output from the cryptographic module in encrypted form or using a split knowledge procedure.

d. Security Level 4:

Security Level 4 provides the highest security level.

Security Level 4 provides a complete envelope of protection around the cryptographic module with the intent of detecting and responding to all unauthorized attempts at physical access. Penetration of the cryptographic module enclosure from any direction has a very high probability of being detected, resulting in the immediate zeroization of all plaintext critical security parameters.

Level 4 also protects encryption module from damage of security in environment conditions or unusual changes outside usual voltage and temperature operation limits of the module.

4.1.2.3 HSM configuration

HSM needs to be configured with some standard parameters. The parameters marked as bellowed are essential. Especially, the two parameters Enable X9.17 for import and

Enable X9.17 for export need to be set to Yes to ensure that there is no error in the ZPK exchange process.

For example: Configuration of HSM Thales 8000

Online>qs

```
PIN length: 06
Encrypted PIN length: 07
Echo: OFF
Atalla ZMK variant support: OFF
Transaction key support: Racal
User storage key length: Double
Single-DES: Enabled
Select clear PINs: Y
Enable ZMK translate command: YES
Enable X9.17 for import: YES
Enable X9.17 for export: YES
Solicitation batch size: 1024
ZMK length: D
Prevent Single-DES keys masquerading as double or triple-length keys: NO
PIN encryption algorithm: A
Card/password authorisation: C
Decimalization tables: PLAINTEXT
Decimalization table checks: Disabled
Authorised State required when Importing DES key under RSA key: YES
Minimum HMAC key length in bytes: 08
Enable PKCS#11 import and export for HMAC keys: YES
Enable ANSI X9.17 import and export for HMAC keys: YES
Enable ZEK encryption of all printable ASCII chars : NO
Enable ZEK encryption of "Base94" ASCII chars : NO
Enable ZEK encryption of "Base64" ASCII chars : NO
Enable ZEK encryption of "Hex-only" ASCII chars : NO
Restrict Key Check Values to 6 hex chars : YES
Enable multiple authorised activities: YES
LMK check: XXXX XXXX XXXX XXXX
```

4.1.3 Key Management

4.1.3.1 Types of Keys

- LMK (Local Master Key or Master File Key): used for storing other types of keys in switch database.
- ZMK (Zone Master Key) or MK (Master Key): used for encrypting/decrypting ZPK and MAK during the key exchange process among NAPAS, financial institutions and member banks. ZMK is 128 bits in length.
- ZPK (Zone PIN Key or PIN Encryption Key or Working Key - WK): This Data Key is used for PIN encryption key, or working key. This key is 128 bits in length.

- MAK (Message Authentication Key): this Data key is used for the MACing process. The MAK can be double length (32H) or single length (16H) for each bank.

The above keys (except LML stored in HSM) will be encrypted by 3DES algorithm and stored in database (allowing to manage keys flexibly, permanent backup/retrieve/store, and meet requirements of increasing numbers of key).

4.1.3.2 Key generation, Delivery and Storage

4.1.3.2.1 LMK

- LMK will be generated with 03 components at random.
- LMK will be stored in HSM at each member banks.

4.1.3.2.2 ZMK

The ZMK generation among NAPAS and member banks is as follows:

If a member bank connects to NAPAS, the procedures for Zone Master Key (ZMK) or Master Key (MK) exchange between NAPAS and such bank will be as follows:

- **Step 1:** The member bank requests in written for MK key exchange to NAPAS.
- **Step 2:** NAPAS's department responsible for HSM administration receives the request and generates a part of MK corresponding to such member bank. The member bank also generates a part of MK dedicated for connection to NAPAS. Normally, MK will be generated from 02 components. In case MK is requested to generate from more than 02 components, NAPAS and the Member bank will discuss and agree on the number of components generated by each party.
- **Step 3:** NAPAS and the Member bank generates MK by the following methods: NAPAS and the member bank will choose a location, date and time and assign personnel to enter MK component into HSM of the other party (with the minutes on MK generation which is signed by such personnel of both parties). The comparison of the results of KCV (Key Check Value) obtained from MK generation on HSM at NAPAS and the Member bank will be done in normal communication way (such as: via telephone, email...) If the result is the same for both Parties, the MK generation is successful. If the result is different, the MK generation is fail and both Parties shall review Step 1 and Step 2 to find out the reason of failure.
- **Step 4:** After being generated successfully, MK will be entered in the systems of NAPAS and the Member bank. The key will be used for the key exchange for encryption of connection between the two Parties.

ZMK and Data Key (ZPK, MAK) shall be stored in HSM or encrypted by LMK in the system of each member.

Note: The member shall focus on the key/component generation to ensure the security of ZMK.

4.1.3.2.3 Data Key

Data keys will include ZPK and MAK to be generated in HSM at random by NAPAS system.

If the key is exchange dynamically, the date keys shall be delivery to members as follows:

- NAPAS encrypts data keys by ZMK and attaches such encrypted keys in key exchange messages to the member bank.
- The member bank decrypts and stores the Data key in HSM or encrypts the key by LMK and stores in the system.
- The member bank Reponses with the successful key exchange message to NAPAS so that both Parties can use new data keys.

4.1.4 Zone Master Key (Master Key)

Master key is the key used to exchange working keys (working keys are encrypted by Master key and sent in 0800/0810 messages). Therefore, it is necessary to secure Master key. Master keys between NAPAS and each member are different. Master keys are generated by HSM of NAPAS and members by combining text-clear of components of both Parties. When creating Master key for a member, there must be participation of 2 parties including a person assigned by NAPAS and at least a person assigned by the member bank. NAPAS defines tasks and responsibilities of Master key manager as follows:

1. Key management assignment

- Person responsible for managing Master Key of the member will be assigned by the member and a person will be assigned by NAPAS.

2. Responsibilities of key managers

- Receive and store key parts securely.
- Control key data, check the data and their secure storage.
- Do not reveal keys to unauthorized people.

- Maintain logs and journals to monitor the access to key data and its usage including access time, date, purpose...
- Destroy expired key parts or the cancellation of old keys in witness with the agreement from NAPAS and the member bank.
- Enter key data into security encryption modules (HSM) when required.

4.2 PIN encryption and decryption

4.2.1 PIN encryption and transfer

The process of PIN encryption and transfer is as follows:

- PIN generation, PIN storage method, encryption key for PIN depends on each member bank, PIN cannot be more than 6 (six) digits.
- PIN transfer in the operation of NAPAS switching system is done through PIN Block. PIN Block format complies with regulations in sub-section "PIN Block Format".
- For PIN security during transfer process via network, the banks must encrypt PIN block before it is transferred from card acceptor devices to switch of acquirer. PIN block of acquirer is secured by keys agreed with NAPAS before it is transferred to NAPAS:
 - + NAPAS receives encrypted PIN blocks from card acquiring bank, decrypts and re-encrypts by the key agreed with card issuing party and sends to card issuing bank without capturing the clear PIN block.
 - + PIN contains 6 digits in maximum (usually 4 or 6 digits).
- In financial transactions through NAPAS system, PIN block format complies with ISO 9564-1 format 0. In which, clear PIN block and PAN (Primary Account Number) are applied with algorithm "XOR", and then encrypted by algorithm "3DES" to create an output of 64 bit encryption block.
- ATM of member banks must have EPP module (Encrypting PIN Pad) supporting 3DES in compliance with ISO 9564-1, ISO 13491-1 and ISO 13491-2. EPP module will encrypt PIN block as soon as receiving PIN entered by customers before sending to host (processing center) of the bank to enhance PIN security for customers.
- Clear PIN Block shall not be present outside EPP or HSM.

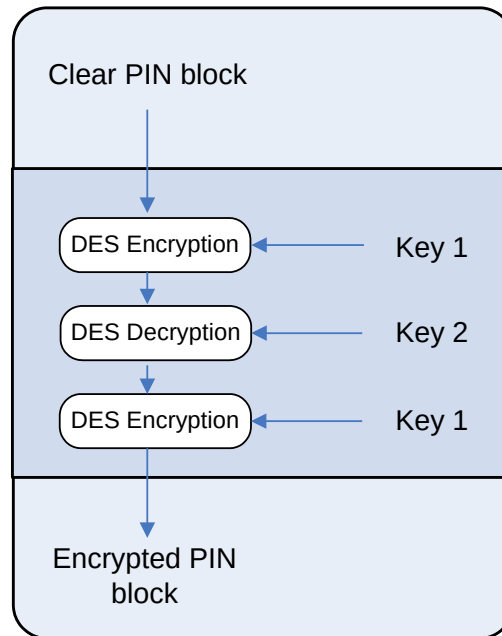


Figure 2. PIN Encryption at ATM (EPP)

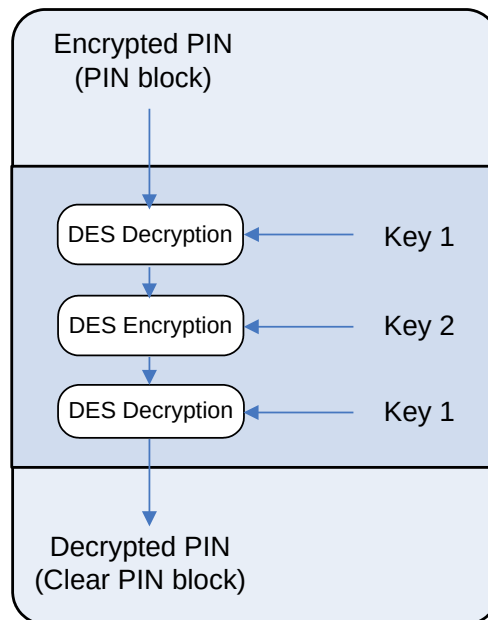


Figure 3. PIN Decryption at Processing Center

4.2.2 PIN Block Format

Algorithm DES (3DES) works with only 64 bit data block input, maximum length of each PIN is 16 digits.

According to ISO 9564-1, structure of PIN data block is 64 bits. The most important 4 bits in this block are located in control field (C) with the following values:

0000	Format 0 (Proposed Format)
0001	Format 1
0010	Format 2 specified in ISO 9564-3
0011	Format 3

PIN Format 0 block is built by module-2 (XOR) with two 64-bit fields: clearPIN field (*with fulfilment number F - Hex system*) and PAN Field with following information:

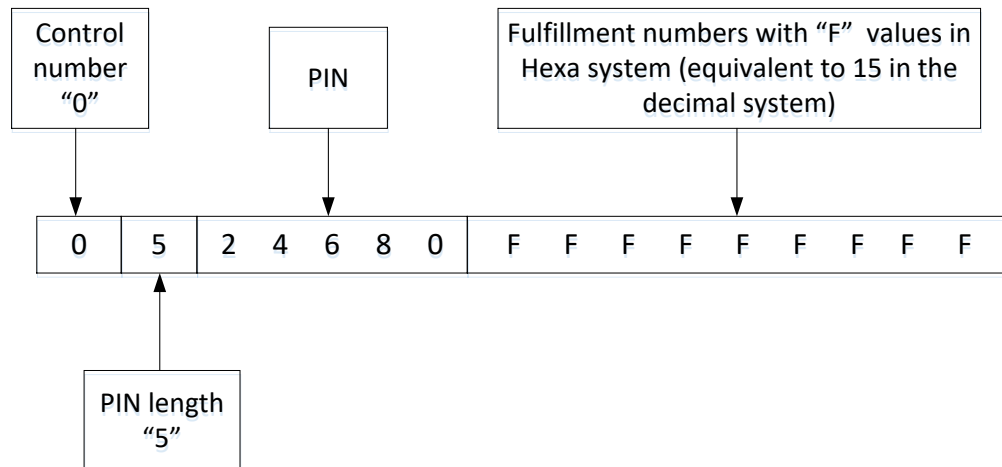
- Clear PIN Block format is as follows:

Bit position	1	5	9	13	17	21	25	29	33	37	41	45	49	53	57	61..64
Value	C	N	P	P	P	P	P/F	P/F	P/F	P/F	P/F	P/F	P/F	P/F	F	F

In which:

C = Control field	0000
N = PIN length	4 bits with values from 0100 (4) to 1100 (12)
P = PIN	4 bits with values from 0000 (0) to 1001 (9)
P/F = PIN/Fulfillment number	This field is defined by N value
F = Fulfillment number (Hexadecimal)	4 bits with value of 1111 (15)

Example: Clear PIN block format 0



- PAN field format is as follows:

Bit position	1	5	9	13	17	21	25	29	33	37	41	45	49	53	57	61..64
Value	0	0	0	0	A1	A2	A3	A4	A5	A6	A7	A8	A9	A10	A11	A12

In which:

0 = Pad digit	4 bit field with 0 value (indicates 0 in binary 0000)
A1...A12 = account number A1 to A12 receive value in the range [0,...,9]	12 right-side numbers of PAN except check digit. A12 is the number before check digit of PAN. If PAN without check digit is less than 12 digits in length, Leading Pad digits will be added to the left if PAN length is less than 12 digits excluding check digit.

4.2.3 PIN encryption algorithm

PIN shall be encrypted by 3DES algorithm with dual key (128 bit). 3DES uses 64 bits in the left of the key to encrypt data, 64 bits in the right of the key to decrypt that encryption result and reuse 64 bits in the left of the key to encrypt the last decryption (The left part of the key must be different from the right part of the key. If 2 parts are the same, then encryption, decryption and encryption once again with one key will be as the same with using a single 56 bit key).

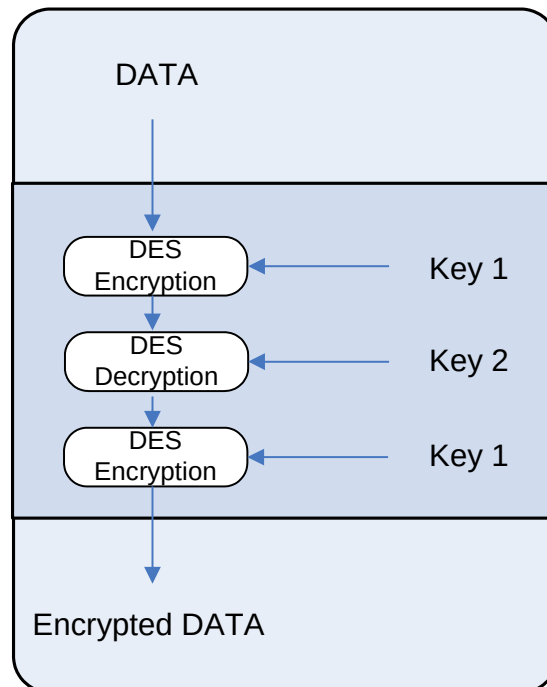
Example: a dual 3DES key (128 bit) with 64 bits in the left (key 1) and 64 bits in the right (key 2) is as bellows:

AAEEAA75BDFDB57F 66AAEEAA66AAEEAA

↑ ↑

Key 1 Key 2

The following diagram describes data encryption with a dual 3DES key:



Using dual 3DES key in switching network requires synchronization and unification of all member banks. This requires member banks to do the followings:

- Upgrading or replacing ATM and HSM.
- Upgrading or re-writing software for ATM network administration and ATM transaction management;
- Replacing or customizing encrypted key storage database in order to be compatible with greater length of keys;
- Generating, exchanging, replacing, loading and storing new 3DES keys;
- Enhancing the checking and certification;
- Canceling currently single keys.

4.3 MAC Generation

4.3.1 Purposes of MAC

Message authentication ensure the integrity of the message during the message transmission among NAPAS, institutions and member banks.

MAC has 02 main purposes:

- Enabling a receiving party to identify that the message remains integrity and unchanged during the transmission.
- Enabling the receiving party to identify the sending party.

To assure the integrity, the authentication includes 2 steps:

- Using MAC calculation algorithm and data encryption key (MAC key or MAK) for selected data block to generate MAC, then attach to MAC in the trailer of message before sending.
- The message receiver use the same MAC algorithm and MAK agreed with the sender to generate MAC with the in-bound message and authenticate such messages by matching new MAC with the received MAC.

4.3.2 Fields for generating MAC (MACing)

MACing will apply to all Pcodes for both financial transactions (cash withdrawal, IBFT...) and non-financial transactions (balance inquiry, mini statement) and for messages 0200/0210/0420/0430.

No MACing applies for 0800/0810 messages.

MACing is mandatory to all transactions processed by NAPAS system (excluding network messages).

The following DE fields will be fixed and used in MACing and only calculated based on the fields in the sent message.

- If bit ON → it will be included in the MAC Data
- If bit OFF → it will be excluded from the MAC Data

Message	Data Element Required for MAC Generation/Validation
---------	---

0200/0210/0420/0430	MSG TYPE, DE2, DE3, DE4, DE5, DE6, DE7, DE11, DE32, DE37, DE38, DE39, DE41, DE42, DE48, DE63, DE90, DE102, DE103
---------------------	--

4.3.3 MAC Generation/Verification

NAPAS system will generate MAC for all out-bound messages and verify MAC for all in-bound messages. This will be done by using the MAK and MACing fields defined above.

DE 128 (16H in length) will be introduced for MAC data in the request/response message.

- For double length MAK key (32H), the MAC will follow ANSI X9.19 standard.
- For single length MAK key (16H), the MAC will follow ANSI X9.9 standard.

MAC generation or validation from Data Element is as follows:

- Data Element with variable length: MAC processing includes length indicator and components of data element.
- Data element with fix length: MAC processing includes components of data element.
- Concatenate all Data Elements that present in the message to form the data for MAC processing (if the Data Element is not present, then it will be omitted)
- If the resulting data is not integral multiple of 8 bytes, trailing padding with binary zero (hexadecimal value of 0x00) to make it a multiple of 8 byte block before sending for the ANSI X9.19 or ANSI X9.9 for the MAC processing.
- MAC processing value in the message, 16 digits (HEX) in length and stored in DE128.

4.3.4 Handling for MAC error

In case MAC is error, NAPAS will send response code as specified in table of error code.

4.3.5 Specific rules: Implement MAC for IBFT service 24/7

- MAC Format: an-16 Contains a signature chain encrypted MAC with a ZAK key
- Encryption algorithm: ISO 9797, MAC with3 padding algorithm, by method 1 (Thales Command M5)

- Periodly, NAPAS will send ZAK (Clear Component) to member, the ZAK (Clear Component) has 16 characters. Member has the responsibility to secure for ZAK (Clear Component).
- Fields is used to calculate MAC: MSG TYPE, DE2, DE3, DE4, DE5, DE6, DE7, DE11, DE32, DE37, DE38, DE39, DE41, DE42, DE48, DE63, DE90, DE102, DE103.
- MAC error handling:
 - o In case of MAC error, when NAPAS receives 0200 message (for both IBFT inquiry and deposit message) from ACQ/ISS: NAPAS will reply with RC=63 (Security Violation) to show "error in handling MAC".
 - o In case of MAC error, when NAPAS receives 0210 (RC=00) from BNB, this is a situation when BNB has deposit money to customer's account, so NAPAS will reply to ACQ/ISS with RC=68:
 - For IBFT Inquiry: ACQ/ISS will decline the transaction.
 - For IBFT Deposit: ACQ/ISS will process like a timeout transaction with RC=68, ACQ/ISS **DON'T** revert the money to customer's account for this transaction.

4.4 Specifications for DLL on checksum value generation and verification in exchanged file

NAPAS provides member banks with DLL to generate and verify checksum fields in exchanged files.

DLL for verification includes 02 functions:

4.4.1.1 Function for generating 32 byte checksum value from an original string input

string getMd5Hash (string input)

string getCS(string MaBM,string input)

MaBM: the security password of each member bank

input: the content for which the checksum value is calculated

4.4.1.2 Function for checking verifying checksum value with an original input string

bool verifyMd5Hash(string input, string hash)

bool verifyCS(string MaBM,string input, string hash)

MaBM: the security password of each member bank

input: the content for which the checksum value is calculated

hash: the string for which the checksum has been calculated

Refer to website: <http://en.wikipedia.org/wiki/MD5> for more information on MD5 decryption algorithm.

Extended Algorithm for Md5:

```
public string GetCS(string input,string MaBM)
{
    string str="";
    string strMa = getMd5Hash(input);
    string strKQ = strMa;
    MaBM = "5" + MaBM + "5";
    if(IsNumeric(MaBM))
    {
        // Security password is a number
        char[] chars = MaBM.ToCharArray();
        for(int i=0; i<chars.Length - 1; i++)
        {
            str = strMa.Substring(Convert.ToInt16(chars[i].ToString()), 20) +
                Convert.ToInt16(chars[i + 1].ToString());
        }
        strKQ = getMd5Hash(str);
    }
    return strKQ;
}
```

5 PGP in file exchange securely

5.1 Introduction on PGP (Pretty Good Privacy)

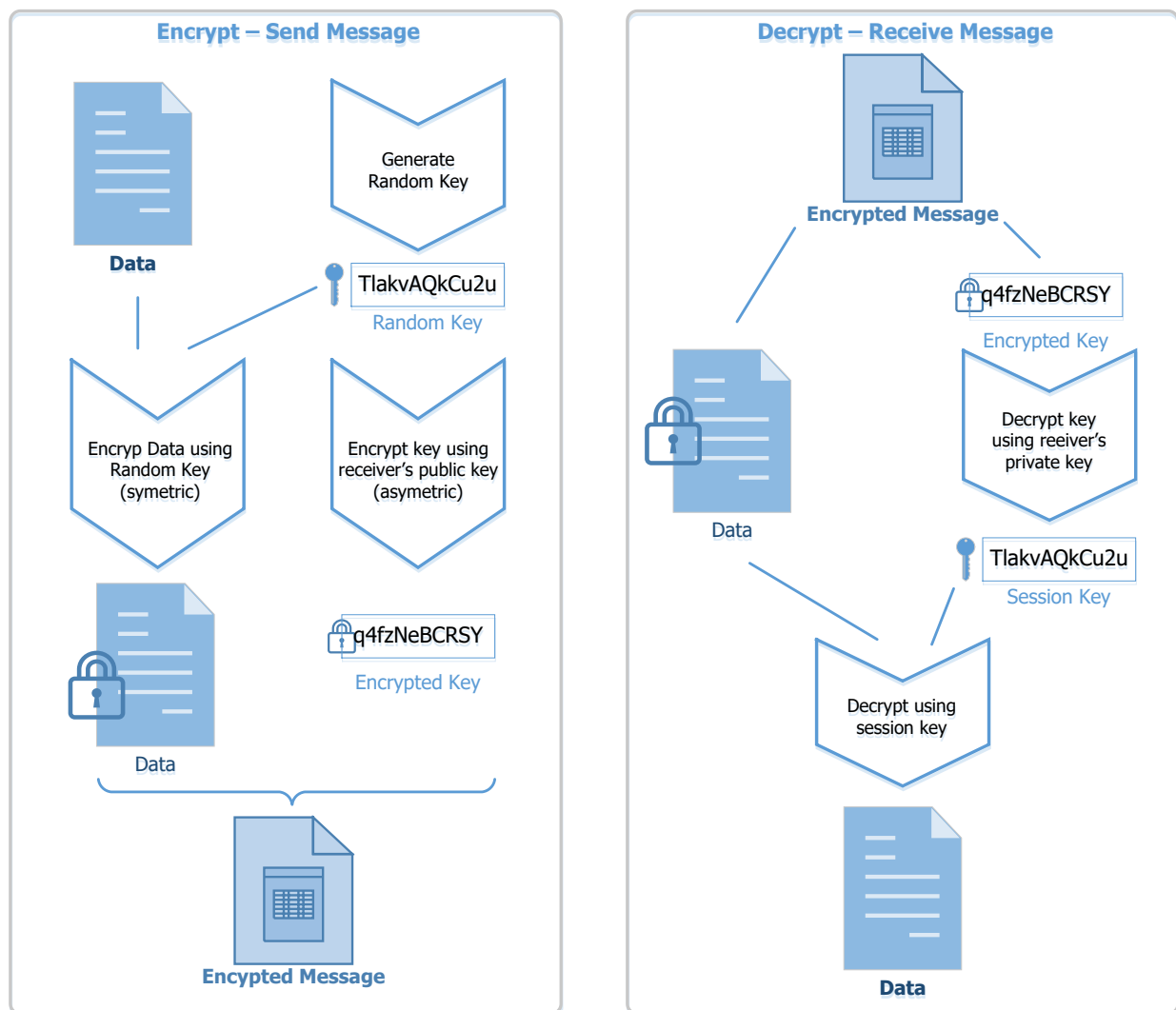
PGP (Pretty Good Privacy) is a popular and strong encryption program that provides cryptographic privacy and authentication for data communication, was created

by Phil Zimmerman in 1991. Softwares based on PGP are often used for encrypting and enhancing the security of data in personal computer, servers and during the process of email communications, IM or file transfer.

Operation:

- PGP encryption uses a serial combination of 3 types of key for encrypting and decrypting data: public key, private key and session key.
- PGP uses 2 types of encryptions: symmetric-key encryption (TripleDES, AES...) and asymmetric-key (RSA).

5.2 Operation Program



Step	Sending Message – Encrypt	Receiving Message - Decrypt
1	The Receiver generates random key – used for encrypting original data	Receive data, separating encrypted data and session key.
2	Encrypt original data using session key (TripleDES, AES) → receiving encrypted message	Decrypt session key using receiver's private key (RSA)
3	Encrypt session key using receiver's public key (asymmetric – RSA)	Decrypting using session key decrypted in previous step
4	Concatenate encrypted data and key into consolidated data sent to the receiver.	Receive the original data

5.3 File transfer securely at NAPAS

5.3.1 Status – Requirements

Every working day, the Reconciliation and Settlement Department of NAPAS sends files which includes private information of customers to partners.

Thus, besides encrypting the transmission line (FTPS), it is required to use an advance encryption program in transferring files including data of cards. The program hereby is PGP.

5.3.2 Specifications

5.3.2.1 Session Key, Private Key, Public Key

- Session key is generated at random (using software or hardware devices) with 128 bits in length.
- Session Key is generated correspondingly to each file (each file will have its own session key).
- A pair of private key, public key with 2048 bits in length will be generated and sent publically to NAPAS via secured manners such as: obtaining a digital certificate from a CA, directly discussion...).
- Private Key of each institution shall be stored and secured by such institution in compliance with Rules and Regulations on security specified by Informatics Technology Department – The state Bank of Vietnam.

5.3.2.2 Encryption Algorithm

- Symmetric cryptography with session key: using strong AES algorithm.
- Asymmetric cryptography with RAS algorithm.

5.3.2.3 File encryption

- Encrypt all original data.
- Name of file after encrypted: [Original name]+[.pgp] (e.g.: abc.dat.pgp)
- Components of encrypted file include:
 - o Record 1: Session key after encrypted by asymmetric algorithm with BASE64 format and omitting the carriage return.
 - o Next Records to trailer: components of file after encrypted with session key, with BASE64 format.

6 Specifications on communication

6.1 Connection protocol

6.1.1 For basic transactions on ATM/POS

NAPAS supports Host-to-Host connection via TCP/IP. Thus, NAPAS will be Server and member banks will be clients. NAPAS will open 01 port for each member and allows only one connection session at the same time to connect to Server.



NAPAS supports Multi-Port based on the round robin method to send message.

- If a request message is received from a particular port, NAPAS will send response to the same port. If the particular port is down, NAPAS will send the response to the next available port.
- The message is rounded robin, regardless ATM or POS transactions.
- Each bank has a unique key mutually used for multiple ports (ZMK, ZPK, and MAK keys are used when multi-port configuration is used).

- When being exchanged, ZPK and MAK keys are sent by NAPAS via ports in a round-robin manner (a key-exchange request can be made via one port but NAPAS can send ZPK and MAK keys via different ports if multi-port configuration is used).
- If multi-port is configured, network message such as Sign-On, Key Exchange, etc... will only be performed in a certain port. There is no need for multiple signon and multiple key exchange.

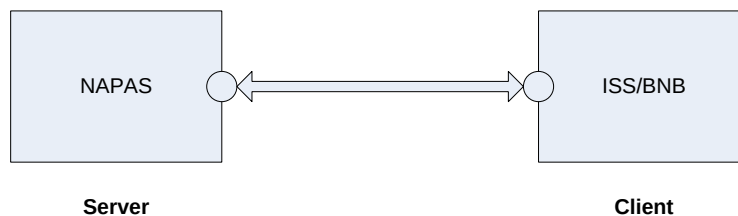
6.1.2 For Online switching Service

For Socket protocol via TCP/IP, NAPAS will be Server and member banks will be clients. Member banks will connect to available port for ATM/POS transactions. If a bank has not connected its ATM/POS system to NAPAS, NAPAS will open another port for such bank.



6.1.3 For Inter-Bank Fund Transfer 24/7 (IBFT)

For Socket protocol via TCP/IP, NAPAS will be Server and member banks will be clients. NAPAS will open a new port for banks.



6.2 Connection Telecommunication

6.2.1 Specifications

To ensure 24/7 operation of the switching services and other services provided by NAPAS to member banks, NAPAS requests members to use 02 connection lines to connect to its system. The primary connection line is Metro Net or Mega WAN with minimum speed at 1Mbps provided by VPNT to connect to NAPAS Data Center and the backup line is Metro net provided by one of the named providers: CMC, FPT or Viettel with minimum speed at 1 Mbps to connect to NAPAS Disaster Recovery Center.

Requirements for network configuration: The network must be secure, then data transferred via such network shall be encrypted by VPN with **pre-shared key** between 02 routers located at NAPAS and member sites.

Requirements for devices at member site: including at least

- 01 optical electrical converter (used for Metro net)
- 01 Mega Wan Modem (used for Mega Wan)
- 01 Router Cisco Series Security bundle with Cisco Router IOS Advanced Security (for encrypting VPN).

Requirements for connection site at bank: The location for devices at banks shall be equipped with fire prevention system, air-conditioner system and UPS to ensure the uninterrupted operation of devices.

Requirements for personnel: To work with NAPAS network team to outsource and set up the connection line and configuration.

Requirements for network administration: To ensure the smooth operation of NAPAS and members, after completing network configuration, member banks shall be responsible for monitoring the network regularly and setting up the connection line from its site to Router at NAPAS. If there is any breakdowns, NAPAS will work with personnel of members to investigate and troubleshoot the error.

6.2.2 Information on network

Member banks sign contract with service providers to setting up the connection line to NAPAS with the following information:

	Primary line	Backup line
Location	Global Data Service., JSC Thang Long Data Center, Plot P-5, Thang Long Industrial Zone, Dong Anh, HN	NAPAS Head Office Pacific Place Building, 83B Ly Thuong Kiet, Trang Hung Dao ward, Hoan Kiem district, Hanoi.
Provider	VNPT	CMC, FPT, Viettel
Type	Metro net or Mega WAN	Metro net
Minimum speed	1 Mbps	1 Mbps
Line encryption	GRE over IP sec	GRE over IP sec

7 Requirements for PCI DSS Compliance

To meet the requirements for security of cardholder information, NAPAS and members shall store (in application log and database) in compliance with PCI DSS as follows:

		Data element	Eligible for storing	Clear tex data
Customer database	Cardholder information	Primary Account Number (PAN)	Yes	No
		Cardholder Name	Yes	Yes
		Service Code	Yes	Yes
		Expiration Date	Yes	Yes
	Sensitive authentication data	Full Track Data	No	Unpermitted for storing
		CAV2/CVC2/CVV2/CID	No	Unpermitted for storing

		PIN/PIN Block	No	Unpermitted for storing
--	--	---------------	----	-------------------------

For files exchange between NAPAS and members (reconciliation file, dispute file, etc. ...) shall meet the following requirements:

- File shall be encrypted in compliance with PGP (**referring to Article 5. PGP in file exchange securely**)
- File between NAPAS and members shall not include sensitive authentication data.

8 Effective document

The NAPAS Technical Specification for switching service takes effect from 01st January, 2017.

9 Document management

Internal reference document:

No.	Document Name
1	BANKNETVN Technical Specification Document (version 1.6.1).
2	SMARTLINK Technical Specification Document (version 2.0).
3	Regulation for Member Organization Participating on the SMARTLINK System.
4	Regulation for Member Organization Participating on the BANKNETVN System.
5	Regulation for Business Settlement and Reconciliation Process on the BANKNETVN System (released at 28th February, 2013).

External reference document:

No.	Document Name
1	ISO 8583-1987 Technical Specification Document.
2	Technical Specification Documents of VISA Organization.

3	Technical Specification Documents of MASTERCARD Organization.
4	Technical Specification Documents of UPI Organization.